



Security Audit & Assessment MECR2123

PROJECT

(Due date: 1 July 2026)

Session 2025/2026-2

**Theme: CONDUCT EXTERNAL
SECURITY AUDITING**

Lecturer: Assoc. Prof. Ts. Dr. Siti Hajar Othman

List of Group Members (Metric No):	1) Shwetha A/P C.Ravichandran (MEC254010) 2) Netrha Shri A/P Rama Moorthy (MEC254040) 3) Keertennah Devi A/P Ponnambalam (MEC254026)
Video and Presentation Link:	https://drive.google.com/drive/folders/1HNWPPVrAwVPVBpFSaiZR024ouCFhSOQ8?usp=sharing

EXTERNAL SECURITY AUDIT REPORT

Project Theme: External Security Audit and Assessment

1. AUDIT TEAM STRUCTURE

Member 1: Netrha Shri A/P Rama Moorthy

Role: Compliance Officer

Responsibilities:

- Define audit scope
- Ensure compliance with ISO/IEC 27001 requirements
- Review baseline control against organizational practices
- Prepare the Executive Summary and Conclusion

Member 2: Shwetha A/P C.Ravichandran

Role: Technical Auditor

Responsibilities:

- Assess technical security controls and systems
- Evaluate authentication, access control, logging, and data protection mechanisms
- Identify technical technical vulnerabilities and weaknesses
- Develop technical recommendations for remediation

Member 3: Keertenah Devi A/P Ponnambalam

Role: Risk Analyst and Documentation/Reporting Lead

Responsibilities:

- Perform risk assessment and risk rating activities
- Develop audit checklists and assessment tables
- Identify areas of non-compliance
- Compile and consolidate audit findings
- Prepare and finalize the audit report and presentation materials

Team Structure Description

The audit team consists of three members responsible for compliance assessment, technical security evaluation, risk analysis and audit reporting. The Compliance officer ensures alignment with ISO/IEC 27001 requirements, the Technical Auditor evaluates security controls and technical safeguards, while the Risk Analyst also serves as the Documentation and Reporting Lead by managing audit documentation and consolidating the final report. This structure ensures that all key audit activities are effectively covered despite the small team size.

2. EXECUTIVE SUMMARY

The results of an external security audit of MediCare Regional Hospital's Telehealth Services, which evaluated MediCare's telehealth services against an ISO/IEC 27001 baseline, revealed discrepancies with vendor oversight, log monitoring, account management, access control, and incident response readiness. Although backup plans and policies exist, the lack of sufficient oversight and compliance measures exposes the organization to unauthorized access, loss of data, and service interruption. To be compliant with ISO/IEC 27001, the audit identified several areas for action, including the need for internal controls such as documented log reviews, restoration verification of backups, strengthened authentication methods, enforcement of account lifecycle management, and periodic vendor compliance assessment.

3. SCENARIO DESCRIPTION AND METHODOLOGY

Security Audit Standard

ISO/IEC 27001 (Information Security Management System)

Overview of Company

The chosen company for this study is MediCare Regional Hospital which is a large sized private health care service provider based in Malaysia. Recently they have extended their service by including telemedicine consultation, online appointments, electronic medical records and managing prescriptions digitally. As a result, the hospital processes a lot of sensitive patient data. This includes personal data, medical history, diagnosis records, billing details, and all types of clinical documentation from doctor-patient interactions.

Due to the increasing use of online healthcare services, MediCare relies heavily on its technology infrastructure to provide a secure method of communication among doctors, patients, pharmacy staff and administrative employees. In recent years, due to an increased demand for the use of telemedicine services in remote areas or at home via computer or mobile device, MediCare has experienced multiple security challenges. Some of these challenges include access control, data protection, system monitoring, employee education about best practices regarding cybersecurity and proper oversight of vendors who may be contracted to assist with providing the service.

3. AUDIT METHODOLOGY

This external audit was done using a structured, standards-based methodology that was based on the ISO/IEC 27001 Annex A control objectives. The audit team used the following methodology:

- **Document and Policy Review**
Examination of MediCare's existing information security policy, access control policy, incident response plan, and backup procedures to establish the baseline of documented practice.
- **Control Mapping**
Each ISO/IEC 27001 baseline control related to the telemedicine scope was mapped against MediCare's actual operational practice to determine the level of compliance such as compliant, partially compliant or non-compliant.
- **Stakeholder Walkthrough**
Interviews and process walkthroughs were simulated with representative roles to understand day-to-day operational practices such as account provisioning, credential sharing incidents, and log review habits.
- **Technical Observation**
Review of system-level configurations for the patient portal, identity and access management system and cloud infrastructure to verify claims such as the presence or absence of multi-factor authentication.
- **Risk Assessment**
Identified gaps were rated for likelihood and impact to prioritize remediation.
- **Reporting**
Findings were consolidated into a checklist of baseline requirements versus observed practice, a risk register, and a set of actionable recommendations which are presented in the following sections.

4. AUDIT SCOPE

The external security audit will evaluate the information security controls implemented within the telemedicine services environment of MediCare Regional Hospital. The audit scope covers the systems, processes, and information assets involved in delivering remote healthcare services.

a) Systems included in the Audit

The audit will assess the security of the following systems:

- Telemedicine web application
 - Patient login portal
 - Doctor consultation portal
 - Video consultation platform
 - Electronic prescription module
- Electronic Medical Record system
 - Patient records database
 - Clinical notes repository
 - Laboratory report management
 - Treatment history records
- Identity and Access Management System
 - User authentication services
 - Role-based access control mechanisms
 - Staff account management system
- Cloud Infrastructure
 - Cloud-hosted patient database
 - Cloud storage services
 - Backup and recovery servers

b) Process included in the audit:

The audit will evaluate the effectiveness of security controls within the following business and IT processes:

- Patient registration and onboarding
- Telemedicine consultation process
- Electronic prescription generation and sharing
- User account creation and termination
- Password management and procedures
- Access rights assignment and review
- Data backup and restoration procedures

- Security monitoring and log review activities
- Incident reporting and response procedures
- Third-party vendor management and oversight

c) Data types included in the audit

The audit will assess the protection of the following information assets:

- Patient personal information
 - Name
 - Identification number
 - Contact information
 - Address
- Patient Healthcare Information
 - Medical history
 - Diagnosis records
 - Laboratory reports
 - Consultation notes
 - Treatment record
 - Prescription information
- Operational and security information
 - User credentials
 - Access logs
 - Audit logs
 - Incident reports
- Financial Information
 - Billing records
 - Payment information

Exclusions from Audit Scope

- The following areas are outside the scope of this audit:
- Physical security controls of hospital facilities
- Medical equipment and diagnostic devices
- Human resource management systems
- Financial management systems unrelated to telemedicine services
- Non-telemedicine healthcare operations

5. FINDINGS

Potential Risks and Weaknesses

The initial evaluation of MediCare Regional Hospital's telemedicine environment has identified several possible threats and vulnerabilities in relation to the confidentiality, integrity, and availability of its information assets that could potentially impact them negatively.

a) **Poor Access Control Management**

During peak operational times, some physicians and nurses temporarily share their individual login credentials so they can quickly obtain access to patients' medical history. This action reduces accountability and enhances the possibility of an unauthorized party obtaining access to confidential patient information.

b) **Absence of Multi-Factor Authentication (MFA)**

Currently, remote access to the telemedicine platform is secured via single-factor authentication, such as username and password authentication. Thus, the absence of multi-factor authentication increases the opportunity for unauthorized parties to gain access through stolen usernames/credentials and phishing scams.

c) **Delays in Disabling Accounts for Resigned Employees**

Accounts created by employees who have resigned from employment with the hospital are not immediately disabled. As such, these dormant accounts exist as viable options for unauthorized access into computerized systems.

d) **Failure to Regularly Monitor System Log Activity**

While automated logs are generated within all systems at the hospital, there does not presently exist a formal procedure for reviewing and analyzing these logs. Therefore, suspicious activity may remain unidentified for an extended period.

e) **Limited Cybersecurity Awareness Training Provided to Hospital Staff**

Limited cybersecurity awareness training is provided for hospital staff. As such, staff members are likely vulnerable to phishing emails, social engineering schemes, and unintentional disclosure of private patient information.

f) **Inadequate Validation of Backup Restoration Processes**

Backups are taken on a regular basis however, periodic restoration validation testing is not completed. Therefore, the hospital may encounter significant challenges when

attempting to recover critical systems in the event of a cyber incident or system failure.

g) Third-Party Related Cybersecurity Vulnerabilities

As a result of employing third-party vendors to provide cloud-based hosting services, telemedicine software, and IT support services, the hospital is exposed to potential cybersecurity-related issues associated with vendor compliance and security controls. Furthermore, consistent reviews of each vendor's compliance and security measures are not being performed.

h) Lack of Formal Incident Response Testing

Although an incident response plan exists, it is not tested via tabletop exercises or simulation drills. Therefore, hospital staff would most likely be unprepared to respond adequately to a cybersecurity incident or data breach if one were to occur.

Compliance with ISO/IEC 27001

The compliance function of this audit ensures that the telemedicine services provided by MediCare Regional Hospital are evaluated in conformance with the baseline criteria of ISO/IEC 27001. This comprises locating non-compliance areas, defining the audit's scope, and connecting organizational operations to the standard's control objectives. Verifying that backup and recovery techniques are regularly assessed, ensuring that incident response strategies are verified and documented, and verifying that access control rules enforce unique credentials and multi-factor authentication are all crucial compliance checks. Vendor management practices are also reviewed to make sure outside vendors meet the hospital's security needs. By carefully comparing MediCare's current practices with ISO/IEC 27001 requirements, the audit finds strengths, exposes weaknesses, and provides useful recommendations to strengthen the hospital's information security posture.

Baseline Requirements

The audit assesses the telemedicine environment at MediCare Regional Hospital using the ISO/IEC 27001 baseline criteria. Access control, incident response, asset protection, backup and recovery, and vendor compliance are some of these criteria. To ascertain if the hospital's procedures fully or partially satisfy the requirement, each control is evaluated.

The telemedicine environment at MediCare Regional Hospital was compared to ISO/IEC 27001 baseline controls during the audit. A few gaps were found:

i. Access Control

Strong authentication and distinct credentials are required by ISO/IEC 27001. Non-compliance arises from staff members sharing login credentials on occasion and the lack of multi-factor authentication.

ii.Account Management

Resigned employees' dormant accounts are still live which is against the rules of prompt account deletion.

iii.Log Monitoring

Suspicious behaviour goes unnoticed since there is no formal review procedure in place when logs are generated.

iv.Backup and Recovery

ISO/IEC 27001's assurance of data availability is not met because regular backups are made but restoration testing is not carried out.

v.Incident Response

There is a plan in place, but it hasn't been tested, therefore it doesn't meet the preparedness criteria.

vi.Vendor Management

Vendor audits are not frequently conducted, despite ISO/IEC 27001's significant emphasis on third-party compliance.

Identification of Strengths, Weaknesses, and Missing Safeguards

- Benefits include regular data backups, clearly defined access roles and a well-established information security policy.
- Weaknesses include the absence of multi-factor authentication, inactive account administration, and restricted log monitoring.
- Missing safeguards include regular incident response drills, restoration testing, and vendor compliance checks.

Its benefits include role-based access control systems, regular backup plans, and a clear information security policy. Vulnerabilities in vendor monitoring, supervision, and authentication, however, indicate areas that require rapid attention.

Checklist: ISO/IEC 27001 Baseline Requirements vs Observed Practices

ISO/IEC 27001 Control Area	Baseline Requirement	Observed Practice at MediCare	Compliance Status
A.5 Access Control Policy	Unique user credentials and MFA required for remote access	Staff occasionally share login credentials and only single-factor authentication used	Non-Compliant
A.9 User Access Management	Timely revocation of access rights upon termination	Resigned employees' accounts remain active for an extended period	Non-Compliant
A.12.4 Logging and Monitoring	Logs must be regularly reviewed and analyzed for anomalies	Logs are generated automatically but no formal review process exists	Non-Compliant
A.12.3 Backup	Backups must be performed and periodically tested for restoration	Regular backups are performed; restoration testing is not conducted	Partially Compliant
A.16 Incident Management	Incident response plan must be documented and tested	Plan is documented but has never been tested via drills or simulations	Partially Compliant
A.15 Supplier/Vendor Relationships	Third-party vendors must be assessed for security compliance	Vendors are engaged but compliance reviews are not routinely performed	Non-Compliant
A.7 Human Resource Security	Staff must receive regular security awareness training	Cybersecurity awareness training is limited and infrequent	Partially Compliant
A.9.4 System and Application Access Control	Role-based access control must be enforced consistently	Role-based access control system is implemented and functioning	Compliant

Risk Assessment

Risk ID	Risk Description	Likelihood	Impact	Risk Rating	Related Control Gap
R1	Unauthorized access via shared credentials	High	High	Critical	Access Control (A.5)
R2	Account compromise due to absence of MFA	High	High	Critical	Access Control (A.5)
R3	Unauthorized access through dormant resigned-staff accounts	Medium	High	High	User Access Management (A.9)
R4	Undetected security incidents due to lack of log review	Medium	High	High	Logging and Monitoring (A.12.4)
R5	Failed data recovery during a real incident due to untested backups	Medium	High	High	Backup (A.12.3)
R6	Inadequate incident handling during an actual breach	Medium	Medium	Medium	Incident Management (A.16)
R7	Third-party or vendor introduced vulnerabilities	Medium	Medium	Medium	Supplier Relationships (A.15)
R8	Staff-driven security incidents such as phishing and social engineering due to low awareness	Medium	Medium	Medium	Human Resource Security (A.7)

6. RECOMMENDATIONS

Based on the findings and risk assessment above, the audit team recommends the following remediation actions, prioritized by risk rating:

- **Enforce Multi-Factor Authentication (Critical – R1, R2)**
Implement MFA for all remote access to the telemedicine platform, patient portal, and doctor consultation portal. This directly closes the largest compliance gap under ISO/IEC 27001 Access Control (A.5).
- **Eliminate Credential Sharing (Critical – R1)**
Enforce a strict non-credential-sharing policy through technical controls for example session timeouts, device-bound logins and staff disciplines paired with awareness training on accountability risks.
- **Automate Account Deactivation (High – R3)**
Integrate the HR offboarding process with the Identity and Access Management system so that resigned employees' accounts are disabled immediately upon termination rather than relying on manual follow-up.
- **Establish Formal Log Review Procedures (High – R4)**
Implement a scheduled log review process supported by a SIEM or log management tool with automated alerting for anomalous access patterns.
- **Conduct Regular Backup Restoration Testing (High – R5)**
Schedule quarterly restoration drills to verify that backups are recoverable and meet recovery time objectives closing the gap under Backup (A.12.3).
- **Test the Incident Response Plan (Medium – R6)**
Conduct at least one tabletop exercise or simulation drill annually to validate the existing incident response plan and identify procedural gaps before a real incident occurs.
- **Formalize Vendor Compliance Reviews (Medium – R7)**
Introduce periodic security compliance audits of all third-party vendors including cloud hosting and telemedicine software providers supported by contractual security clauses.

- **Expand Cybersecurity Awareness Training (Medium – R8)**

Increase the frequency and depth of staff training to cover phishing recognition, social engineering, and safe handling of patient data with periodically simulated phishing tests to measure effectiveness.

Implementing these recommendations in order of priority will bring MediCare Regional Hospital's telemedicine environment substantially closer to full ISO/IEC 27001 compliance while directly reducing the highest-rated risks identified in this audit.

Executive Summary

MediCare Regional Hospital is a private healthcare provider that is expanding its telemedicine services. To ensure that those services meet the international standards for information security (ISO 27001) an external security audit was conducted. The audit included a review of the telemedicine web application, the electronic medical records (EMR) system, the identity and access management (IAM) infrastructure and the cloud-hosted patient data. Each of these systems was evaluated through a combination of document review, control mapping, simulated stakeholder walkthroughs and technical observation. The audit identified eight primary risk areas with credential sharing and the lack of multi-factor authentication being critical due to both the likelihood of occurrence and the potential impact to patient data confidentiality. Other risks include account deactivation, log monitoring, testing backup restorations, testing incident response and lack of oversight for vendor compliance. MediCare has demonstrated some strengths, specifically, within the areas of role-based access control; and having an information security policy. The gaps and weaknesses identified during the audit resulted in MediCare being placed in a non-compliant or partially compliant status in 6 of the 8 ISO 27001 control areas which were assessed. This report provides a summary of the findings from the audit, a compliance checklist for each control, a risk register and a list of prioritized recommendations to bring MediCare's telemedicine environments into full compliance with ISO 27001 standards.

7. Conclusion

Although MediCare Regional Hospital has set up fundamental security procedures, the audit concluded that some enhancements are necessary to satisfy global requirements. The hospital may improve patient data availability, confidentiality, and integrity while maintaining ISO/IEC 27001 compliance by resolving difficulties with vendor management, monitoring, and authentication. By putting these suggestions into practice, risk exposure will decrease and confidence in MediCare's telemedicine services as a dependable and safe healthcare platform will rise